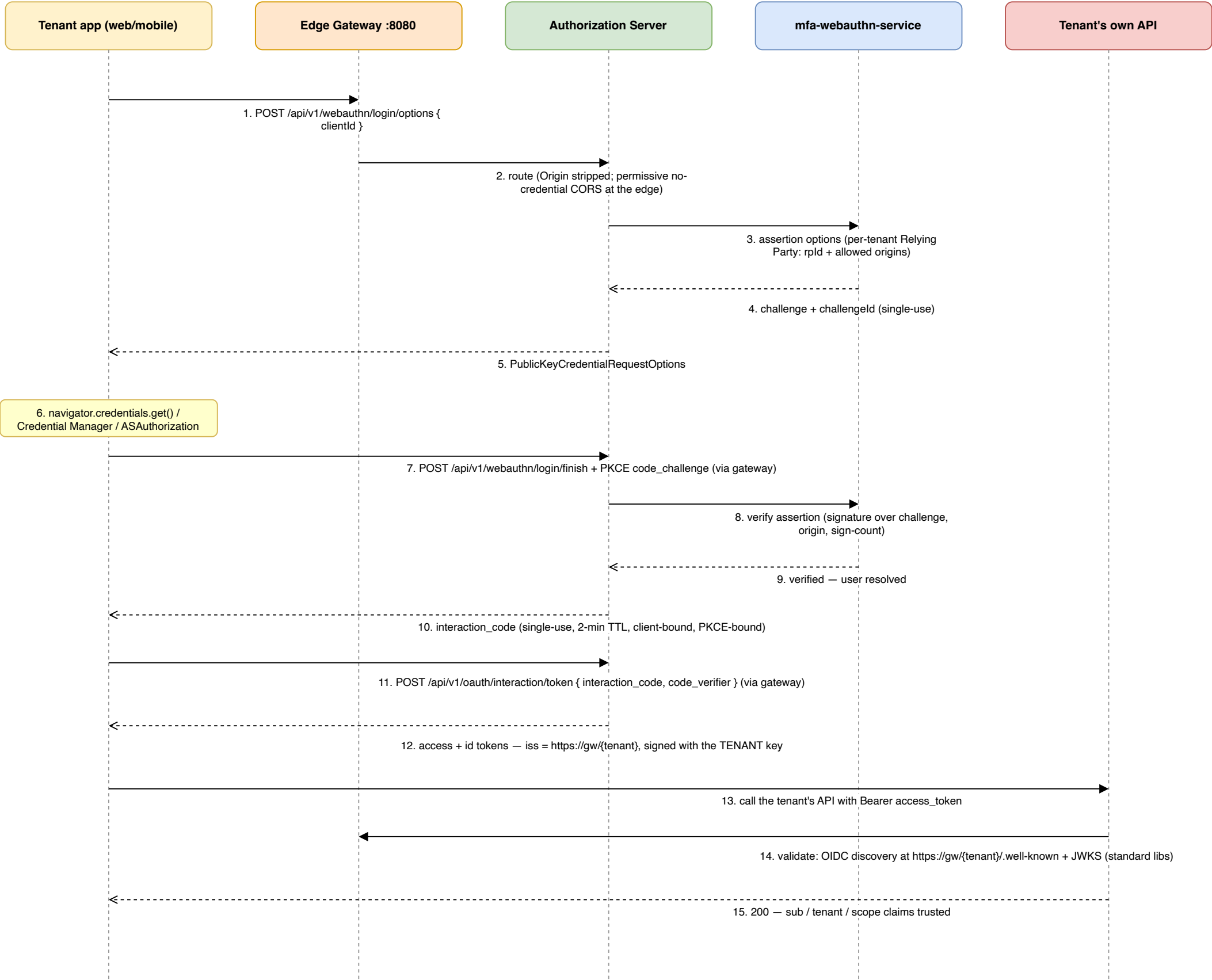


Embedded passkey login in a tenant's own app — WebAuthn + interaction-code exchange



Zero-trust: the ceremony proves possession of the passkey against a single-use server challenge (phishing-resistant); the interaction code is PKCE-bound so only the app instance that started the flow can redeem it. The minted tokens are standard OIDC tokens with the per-tenant issuer — the tenant's own API validates them with any off-the-shelf JWT library via the gateway discovery endpoints, never by trusting the network.